

HACKATHON BUILD • OWASP JUICE SHOP

# Antibody

An autonomous agent that closes a security hole without closing the business, and shows the evidence.

Guild AI

Semgrep

ClickHouse

Senso

Akash

## THE PROBLEM

# An AI fix is easy to demo and hard to trust.

### **It grades itself**

The model says the patch works, and nothing else checks that claim.

### **It breaks the app**

The simplest way to block an injection is to block search entirely.

### **Nobody can check later**

Once it ships, there's no record of what ran, against what, or why.

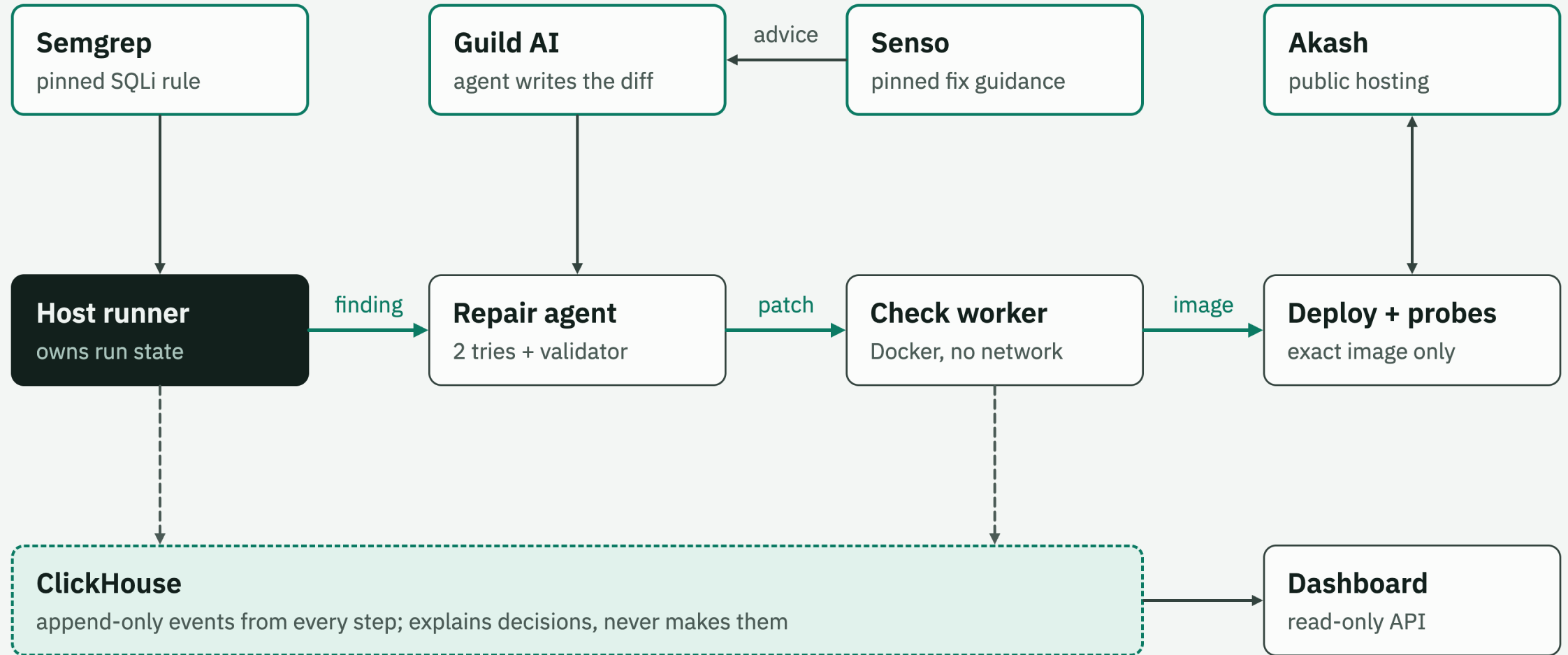
## WHAT IT DOES

# One defect, four steps, every step recorded



Every step writes an event to **ClickHouse**. The dashboard reads those events and nothing else.

# Components and how they connect



Antibody · 4 · teal outline = sponsor · teal arrows = the repair path · dashed = events only

SPONSORS

# Five sponsors, each with one job

| Sponsor    | Job in the run                         | What it can't decide                |
|------------|----------------------------------------|-------------------------------------|
| Semgrep    | Finds the defect with a pinned rule    | Can't use a rule whose hash changed |
| Senso      | Retrieves OWASP and Sequelize guidance | Advisory only; the checks decide    |
| Guild AI   | Agent session writes the patch         | Sees one file, never the answer key |
| Akash      | Hosts the fix and the dashboard        | Deploys only the image that passed  |
| ClickHouse | Stores every event from every step     | Records decisions, never makes them |

Each sponsor sits behind one small adapter. If a sponsor fails, the run records the failure; nothing fakes a result.

# The model proposes. The host decides.

## GATE 1

### Pinned inputs

Rule and test suite must match their recorded hashes.

## GATE 2

### Scope

The patch may touch only routes/search.ts. Checked twice.

## GATE 3

### Host identity

The host hashes each patch; model claims are ignored.

## GATE 4

### Sandbox checks

No network, no privileges. Normal search must still work.

## GATE 5

### Deploy gate

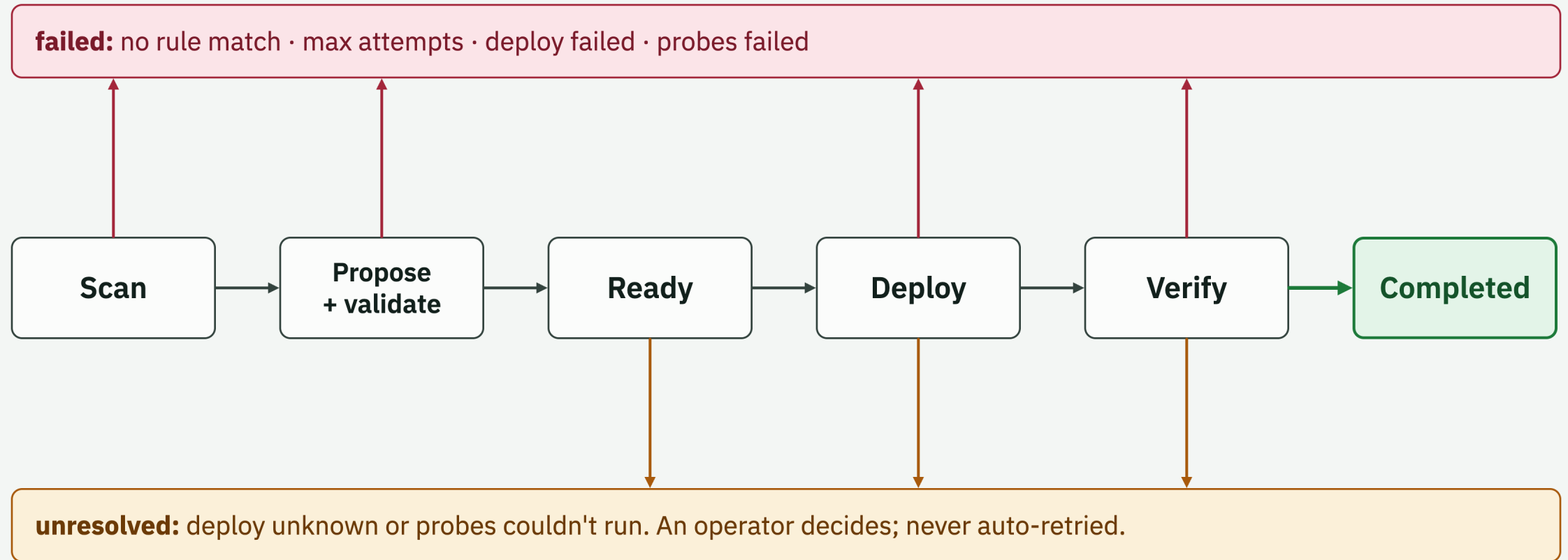
Akash gets only the exact image digest that passed.

## GATE 6

### Outside proof

Public probes finish the run, not "deploy accepted".

# Every run ends in one of three states



# A record you can read, and a check you can rerun

## What ClickHouse records

- Every state change in the run
- Each patch proposed or rejected
- Check results, tied to the exact image
- Whether the fix matches upstream's own answer
- Deploy result and every outside probe

The dashboard returns an error, never an empty list, when the store is down.

## Check it yourself

```
python scripts/probe_public.py
--url <public URL>
--mode candidate
```

It runs normal searches, a single quote, and the injection payload against the live site. You don't need credentials, our database or our servers.

# Where it stands

## ✓ Working today

- Real adapters for all five sponsors, unit-tested
- Offline build-and-check sandbox
- Akash deploys with crash recovery
- Evidence API and dashboard, built in CI

## 🔧 Next

- Fix the patch-hash handoff so a correct fix passes end to end (one line)
- Generate the run report, including which sponsors ran
- Operator commands for rollback and restart recovery

# One hole fixed, with proof anyone can rerun.

Juice Shop still has its other deliberate vulnerabilities. Antibody claims exactly one fix, checked for one revision.

GUILD AI · SEMGREP · CLICKHOUSE · SENSO · AKASH